Davante

3

CIBERSEGURIDAD

Seguridad lógica: Criptografía y sistemas de identificación

ÍNDICE

1. Introducción y contextualización práctica 3

2. Componentes de la seguridad lógica 4

3. Criptografía simétrica o de clave privada: Algoritmos y aplicaciones 5

4. Caso práctico 1: "Encriptación con GPG" 6

5. Criptografía asimétrica: Algoritmos y aplicaciones 7

6. Funciones mezcla o resumen (hash) 9

   6. 1. Algoritmo MD5 10

7. Sistemas de identificación 10

   7. 1. La distribución de claves 11

   7. 2. La infraestructura de clave pública (PKI) 11

8. Caso práctico 2: "Algoritmo MD5" 11

9. Listas de control de acceso 12

10. Resumen y resolución del caso práctico de la unidad 13

11. Bibliografía 15

© Davante 978-84-10384-03-3

Reservados todos los derechos. Queda rigurosamente prohibida, sin la autorización escrita de los titulares del copyright, bajo las sanciones establecidas en las leyes, la reproducción, transmisión y distribución total o parcial de esta obra por cualquier medio o procedimiento, incluidos la reprografía y el tratamiento informático.

Objetivos

Describir las diferencias que existen entre la criptografía simétrica y la criptografía asimétrica.

Reconocer los principales algoritmos de clave pública y de clave privada.

Reconocer las ventajas y aplicaciones de la función resumen hash.

Identificar las principales aplicaciones de la criptografía simétrica y la criptografía asimétrica.

Conocer los principales sistemas de identificación y el uso de listas de control de acceso.

1. Introducción y contextualización práctica

La seguridad lógica es un punto a tener muy en cuenta en el ámbito de la protección de la información y de los sistemas informáticos. En este tema, estudiaremos los diferentes elementos que contribuyen a salvaguardar la **integridad, confidencialidad y disponibilidad de los datos**. Uno de sus pilares fundamentales es la criptografía, que puede dividirse en dos grandes grupos principales: la **criptografía simétrica** o de clave privada y la **criptografía asimétrica** o de clave pública.

Se hará una descripción del funcionamiento de cada tipología, los algoritmos principales que utilizan cada tipo de criptografía y, finalmente, las principales aplicaciones de cada una de estas. Para cerrar la criptografía, se estudiará la función resumen, también conocida como función hash, que asocia una clave a un único archivo, mensaje o documento. La obtención de este valor se realiza a través de algoritmos matemáticos complejos.

Además, se presentarán los sistemas de identificación, como la firma electrónica, los certificados digitales y la distribución de claves, así como la infraestructura de clave pública (PKI) y el DNI electrónico y, por último, las listas de control de acceso.



Fig.1. La criptografía, clave para la seguridad informática.

A continuación, vamos a plantear un caso práctico a través del cual podremos aproximarnos de forma práctica a la teoría de este tema.

Escucha el siguiente audio donde planteamos la contextualización práctica de este tema. Encontrarás su resolución en el apartado 'Resumen y resolución del caso práctico'.

Audio Intro. "*Actuación frente a un ciberdelito*"

https://on.soundcloud.com/iS83AytH5poAYÇ9Vm07

2. Componentes de la seguridad lógica

La seguridad lógica desempeña un papel fundamental en la protección de los sistemas informáticos contra amenazas y ataques cibernéticos. Su objetivo es salvaguardar la **integridad, confidencialidad y disponibilidad** de la información almacenada y procesada en los sistemas.



Fig.2. Los candados y las llaves suelen usarse como metáforas visuales en el desarrollo de sistemas seguros.

El primer componente clave es la **criptografía**, que se encarga de proteger los datos mediante técnicas de cifrado. Existen diferentes tipos de criptografía, como el cifrado de clave secreta (simétrica o privada) y el cifrado de clave pública (asimétrica).

Otro componente importante de la seguridad lógica son los **sistemas de identificación**, que permiten autenticar y verificar la identidad de los usuarios. La firma electrónica es una técnica utilizada para autenticar documentos digitales y asegurar su integridad. Los certificados digitales desempeñan un papel crucial al garantizar la autenticidad de los organismos y facilitar el intercambio seguro de información.

Además, la seguridad lógica implica establecer políticas de **contraseñas sólidas y seguras** para proteger las cuentas y sistemas de accesos no autorizados. Estas políticas pueden incluir requisitos de longitud, complejidad y periodicidad de cambio de contraseñas.

Sabías que...

Según varios estudios de seguridad, las contraseñas más comunes incluyen combinaciones sencillas como “123456”, “password” o “qwerty”, o incluso términos populares como “football” o nombres de famosos.

En cuanto al almacenamiento de la información, es importante implementar políticas adecuadas y utilizar **medios de almacenamiento externo seguros**, como DAS (Direct *Attached Storage*), NAS (*Network Attached Storage*) y SAN (*Storage Area Network*). Asimismo, la realización de copias de seguridad y la creación de imágenes de respaldo son prácticas esenciales para garantizar la **disponibilidad** de los datos en caso de fallos o incidentes.

Audio 1. “*La máquina enigma*”

https://bit.ly/43h5Lh4

3. Criptografía simétrica o de clave privada: Algoritmos y aplicaciones

La criptografía simétrica, también conocida como cifrado de clave secreta o privada, utiliza una única clave tanto para el cifrado como para el descifrado de los datos. La clave se comparte entre el remitente y el receptor. El algoritmo de cifrado toma la clave y la información original, y realiza una serie de operaciones matemáticas para convertir los datos en un formato cifrado. Luego, la clave se utiliza nuevamente para descifrar los datos cifrados y restaurarlos a su forma original. El cifrado de clave secreta es rápido y eficiente, pero requiere que las partes involucradas compartan y mantengan segura la misma clave.

Los principales algoritmos simétricos que se utilizan son DES, AES o ChaCha20, y se describen a continuación:

- **DES**: Uno de los primeros algoritmos de cifrado simétrico; en la actualidad ha caído su utilización debido a que se considera inseguro para muchos propósitos, ya que tiene una clave muy corta (es de 56 bits), lo que provoca que se pueda romper relativamente rápido.

- **AES**: Algoritmo de encriptación utilizado en la actualidad, tanto para software como para hardware. Se trata de un algoritmo de codificación por bloques (con un tamaño de bloque fijo de 128 bits). La clave sí presentará un tamaño variable (128, 192 o 256 bits). El funcionamiento de este algoritmo se basa en la construcción de matrices de 4x4 sobre las que se aplican varias rondas de cifrado.

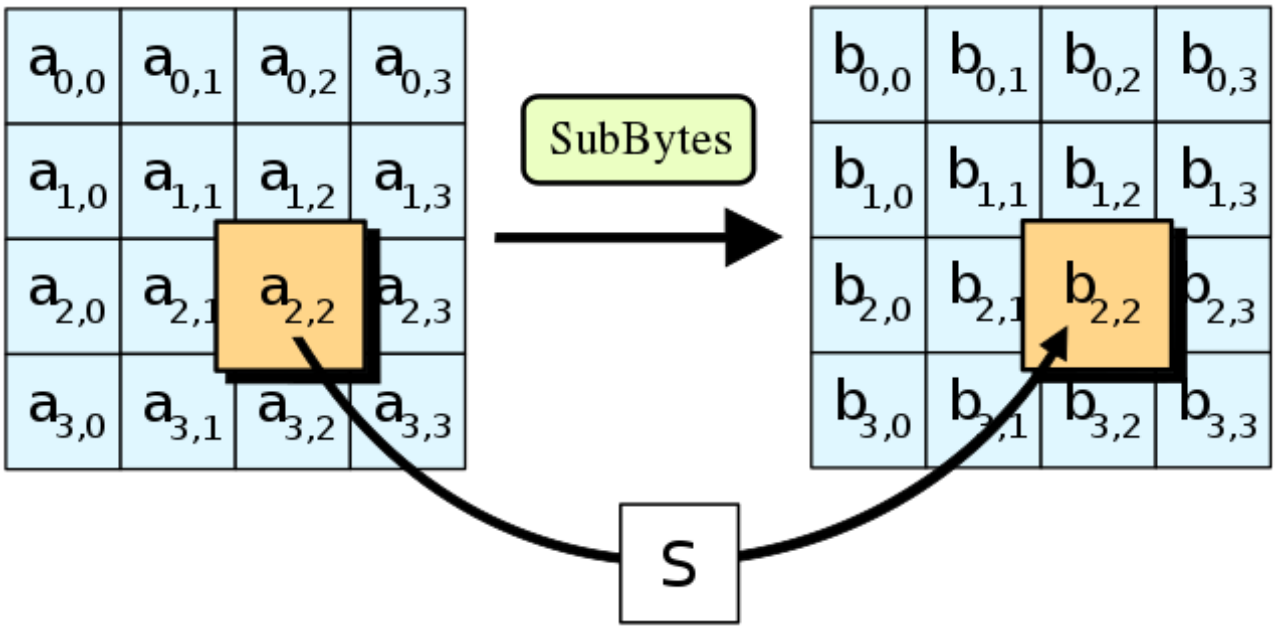


Fig.3. Algoritmo AES.

- **ChaCha20**: Este algoritmo utiliza cifrado de flujo; es el algoritmo empleado en casi todas las conexiones HTTP o SSH.

El sistema operativo Ubuntu utiliza la **aplicación GPG**, la cual permitirá la encriptación de archivos para que solo los usuarios a los que se dirige el paquete puedan descifrarlos. La sintaxis de uso para la **encriptación simétrica** es la siguiente:

gpg –[cd] [Archivo]

Parámetro -c para encriptar clave simétrica el archivo.

Parámetro -d [Archivo] para desencriptar el archivo.

En el caso del sistema operativo Windows, algunas de las aplicaciones más utilizadas son BitLocker. Esta herramienta es oficial para Windows y permite realizar el cifrado de discos y unidades USB. La aplicación se encuentra en el menú 'Sistema y seguridad', dentro del 'Panel de control'. Existen otras herramientas de encriptación de archivos en Windows, como VeraCrypt o AES Crypt.

Enlaces de interés...

En el siguiente enlace encontrarás un vídeo práctico sobre la encriptación con gpg en el que se generan llaves públicas y privadas: https://www.youtube.com/watch?v=jJhjDdRhVqU

4. Caso práctico 1: "Encriptación con GPG"

Planteamiento: El uso de la herramienta GPG nos va a permitir realizar la encriptación de todo tipo de ficheros y documentos, de uno o más de uno.

De nuevo, como responsables del área de seguridad, se nos plantea describir el proceso completo con los comandos utilizados para **encriptar** con clave simétrica un único archivo, el fichero3.txt, y, posteriormente, el proceso para **desencriptarlo**.

Nudo: Para realizar este proceso se debe tener en cuenta lo siguiente:

Encriptado simétrico

gpg -[cd] [Archivo]

Parámetro -c para encriptar clave simétrica el archivo.

Parámetro -d [Archivo] para desencriptar el archivo.

Desenlace: El algoritmo de expresiones utilizadas por línea de comandos se describe a continuación.

1. Nos colocamos en el directorio en el que se ha colocado el fichero fichero3.txt. Para comprobar si el fichero buscado está en esta ruta, utilizamos el comando **ls -la**.

- **Encriptamos** usando la expresión **gpg -c fichero3.txt**.
- Si ahora se intenta visualizar el **contenido**, este resultará **ilegible**.
- **Desciframos el fichero** gpg -d fichero3.txt.gpg.

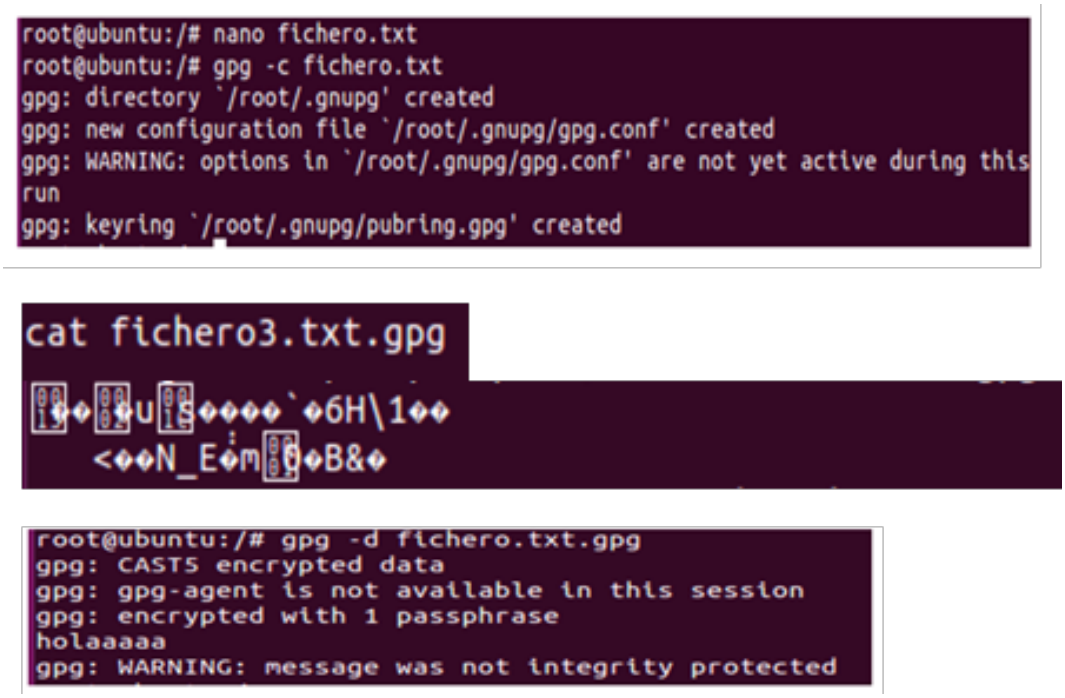


Fig.4. Encriptación y desencriptación.

5. Criptografía asimétrica: Algoritmos y aplicaciones

Por otro lado, el cifrado de clave pública, también conocido como cifrado asimétrico o criptografía asimétrica, utiliza un par de claves relacionadas matemáticamente: una clave pública y una clave privada. La clave pública se comparte libremente y se utiliza para cifrar los datos. Una vez que los datos están cifrados con la clave pública, solo la clave privada correspondiente puede descifrarlos. La clave privada debe mantenerse en secreto y solo el destinatario debe tener acceso a ella. El cifrado de clave pública es especialmente útil para establecer comunicaciones seguras a través de canales inseguros, como Internet.

Los principales algoritmos asimétricos o de clave pública que encontramos en la actualidad son **RSA o DSA**. Recordemos que estos algoritmos ralentizan el proceso debido al tamaño de las claves.

- **RSA (Rivest, Shamir y Adleman)**: Uno de los algoritmos de clave pública más presentes en la actualidad. El funcionamiento de este algoritmo se basa en que el destinatario del mensaje genera una clave pública y otra privada; después, el mensaje se cifra usando la clave pública. Para descifrar el mensaje, el destinatario usará su clave privada.

A continuación una figura sobre claves RSA:

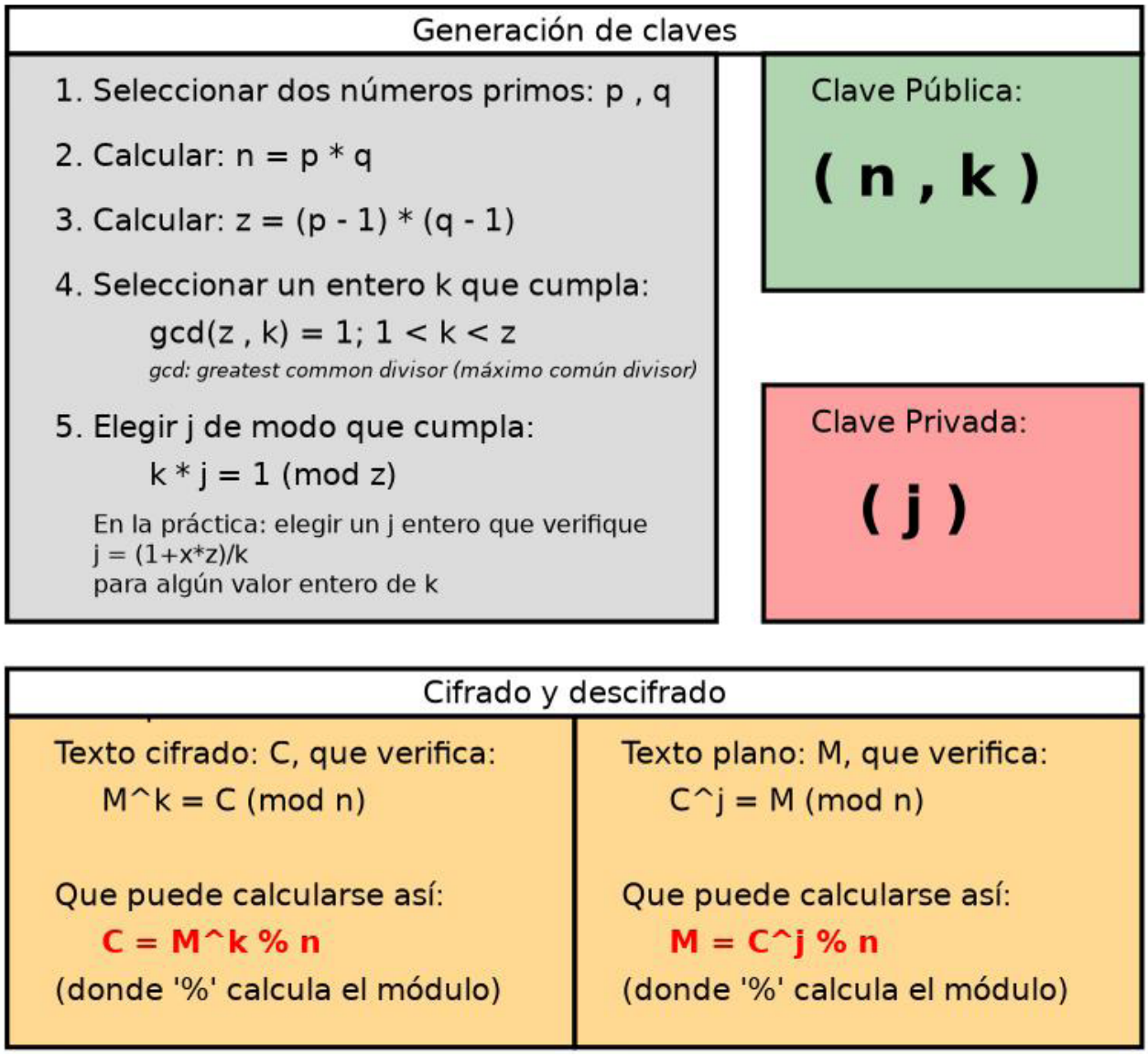


Fig.5. Claves RSA.

- **DSA (*Digital Signature Algorithm*, Algoritmo de Firma Digital)**: Algoritmo asimétrico que **implica el uso de firma digital**, por lo que supone un incremento de la seguridad con respecto a RSA.

Pasos del funcionamiento del DSA
1. Se genera la clave pública y la clave privada
2. Se genera la firma digital con la que el emisor puede realizar las acciones necesarias para el envío, la recepción, la encriptación y la desencriptación.
3. El receptor, que conoce la clave pública, realiza las operaciones necesarias para verificar la autenticidad de la firma.

Tabla.1. Funcionamiento del DSA.

Al igual que en el caso de la criptografía simétrica, los sistemas operativos incluyen aplicaciones para criptografía asimétrica. De nuevo, en Ubuntu se usa la herramienta GPG con la siguiente sintaxis:

Para generar claves pública y privada: **gpg --en-key**

Para consultar las claves: **gpg -k**

Exportar la clave privada: **gpg -output [archivoDestino] --export [ID de la clave pública]**

Importar la clave privada: **gpg --import [archivoDestino]**

6. Funciones mezcla o resumen (hash)

Las funciones de mezcla o resumen, conocidas como funciones hash, son utilizadas para generar una representación única y fija de un conjunto de datos, independientemente de su tamaño. Estas funciones aplican algoritmos matemáticos que transforman los datos en una cadena de longitud fija, también llamada hash o resumen. Las funciones hash son unidireccionales, lo que significa que no se pueden recuperar los datos originales a partir del hash. Además, una pequeña alteración en los datos originales resultará en un hash completamente diferente. Las funciones de mezcla o resumen se utilizan para verificar la integridad de los datos y garantizar que no hayan sido modificados durante la transmisión o el almacenamiento.

Algunas de las **aplicaciones** principales de la función hash son:

- Se utiliza habitualmente en la gestión de identificadores y contraseñas.
- Permite determinar de forma ágil si un documento o mensaje se ha visto alterado durante su transmisión.
- Se usa en la gestión de los blockchains.

Existen multitud de codificaciones hash en la actualidad, algunas de las utilizadas son **DES** y **MD5.**

Enlaces de interés...

Te recomendamos acceder a este enlace dónde encontrarás un amplio listado sobre múltiples tipos de hash: https://binariocero.com/articulos/que-son-las-firmas-de-archivos-hash-y-cuales-son-sus-tipos

6. 1. Algoritmo MD5

Uno de los algoritmos más utilizados para la creación de funciones resumen (hash) es el conocido como MD5. Este algoritmo permite generar un valor único de cada fichero que no podrá verse duplicado.

En el caso de una organización o empresa, se deja en un servidor las claves de conexión de un software de desarrollo; el técnico informático encargado de esto genera un md5 asociado a estos ficheros iniciales; para comprobar que no han sido alteradas las claves o los ficheros, se calcula en el destino el nuevo md5; si coincide el contenido, no habrá sido alterado.



Fig.6. Diagrama ejemplo MD5.

man md5sum

md5sum /ruta/archivo

Vídeo 1. "*GPG, sitio oficial y manual*"

https://vimeo.com/1089644642/730554ae37

7. Sistemas de identificación

Los sistemas de identificación desempeñan un importante papel en la **seguridad** de las comunicaciones y la **autenticación** de las personas en entornos digitales. Estos sistemas se basan en técnicas criptográficas para verificar y garantizar la identidad de los usuarios. En España podemos encontrar comúnmente estos tipos de sistemas de identificación:

1. **Firma electrónica**: Es una técnica utilizada para autenticar documentos digitales y asegurar su integridad. Funciona mediante el uso de algoritmos criptográficos para generar una firma digital única y asociarla con el documento. La firma electrónica proporciona una forma de verificar la autenticidad del documento y asegurar que no ha sido alterado desde su firma.

2. **Certificados digitales**: Son documentos electrónicos utilizados para autenticar la identidad de una persona u organismo a través de la red. Son emitidos por autoridades de certificación confiables y contienen información sobre la entidad y su clave pública. Estos certificados se utilizan para establecer conexiones seguras y confiables, así como para garantizar la integridad de los datos transmitidos.

3. **El DNI electrónico**: Es un sistema de identificación que utiliza tecnología criptográfica. El DNI electrónico incorpora un chip inteligente que almacena datos personales y una clave privada única asociada a la identidad del titular. Esta clave privada se utiliza para autenticar y firmar electrónicamente documentos y transacciones. El DNI electrónico permite a los ciudadanos realizar trámites en línea de forma segura y autenticada, protegiendo su identidad y evitando fraudes.



Fig.7. Una persona utilizando un DNI electrónico.

7. 1. La distribución de claves

La distribución de claves es un aspecto muy a tener en cuenta en la seguridad de los sistemas criptográficos. Implica la **transmisión segura de claves criptográficas** entre las partes involucradas en una comunicación. La distribución de claves puede realizarse de diferentes maneras, bien a través de canales seguros o bien utilizando algoritmos de intercambio de claves, como Diffie-Hellman. Garantizar la distribución segura de las claves es esencial para prevenir el acceso no autorizado a la información cifrada.

7. 2. La infraestructura de clave pública (PKI)

La infraestructura de clave pública (PKI) es un **conjunto de políticas, procedimientos y componentes tecnológicos** que se utilizan para **gestionar y garantizar la seguridad de los certificados digitales y las claves públicas**. La PKI proporciona un marco de confianza que permite a las entidades verificar la autenticidad de los certificados y establecer conexiones seguras. Incluye componentes como autoridades de certificación, repositorios de certificados y servicios de validación.

8. Caso práctico 2: “Algoritmo MD5”

Planteamiento: El algoritmo MD5 permite generar un valor único de cada fichero que no podrá verse duplicado. Se nos pide crear una nueva carpeta o directorio que contendrá cinco ficheros y después realizar las siguientes acciones y comprobaciones:

- Encriptación de todo el contenido con MD5.
- Modificar el contenido de uno de los ficheros.
- Comprobar de nuevo el MD5 y extraer conclusiones.

Nudo: En primer lugar, para la creación de cinco nuevos ficheros, se puede utilizar el comando **nano** seguido del nombre de cada archivo. El contenido de cada fichero puede ser cualquiera.

Para crear un nuevo directorio se emplea el comando **mkdir** seguido del nombre que se le desea asignar a la carpeta.

Desenlace: Tras la creación de cada fichero, se realizan las acciones solicitadas.

- Se encripta todo el contenido de la carpeta y se redirecciona la salida a un fichero.
- Se comprueba si el contenido se ha visto alterado.
- Se modifica el contenido de uno de los ficheros anteriores; basta con cambiar el contenido de cualquiera de ellos en una sola letra.

Al generar de nuevo el código resumen, se mostrarán aquellos archivos que se han visto alterados.

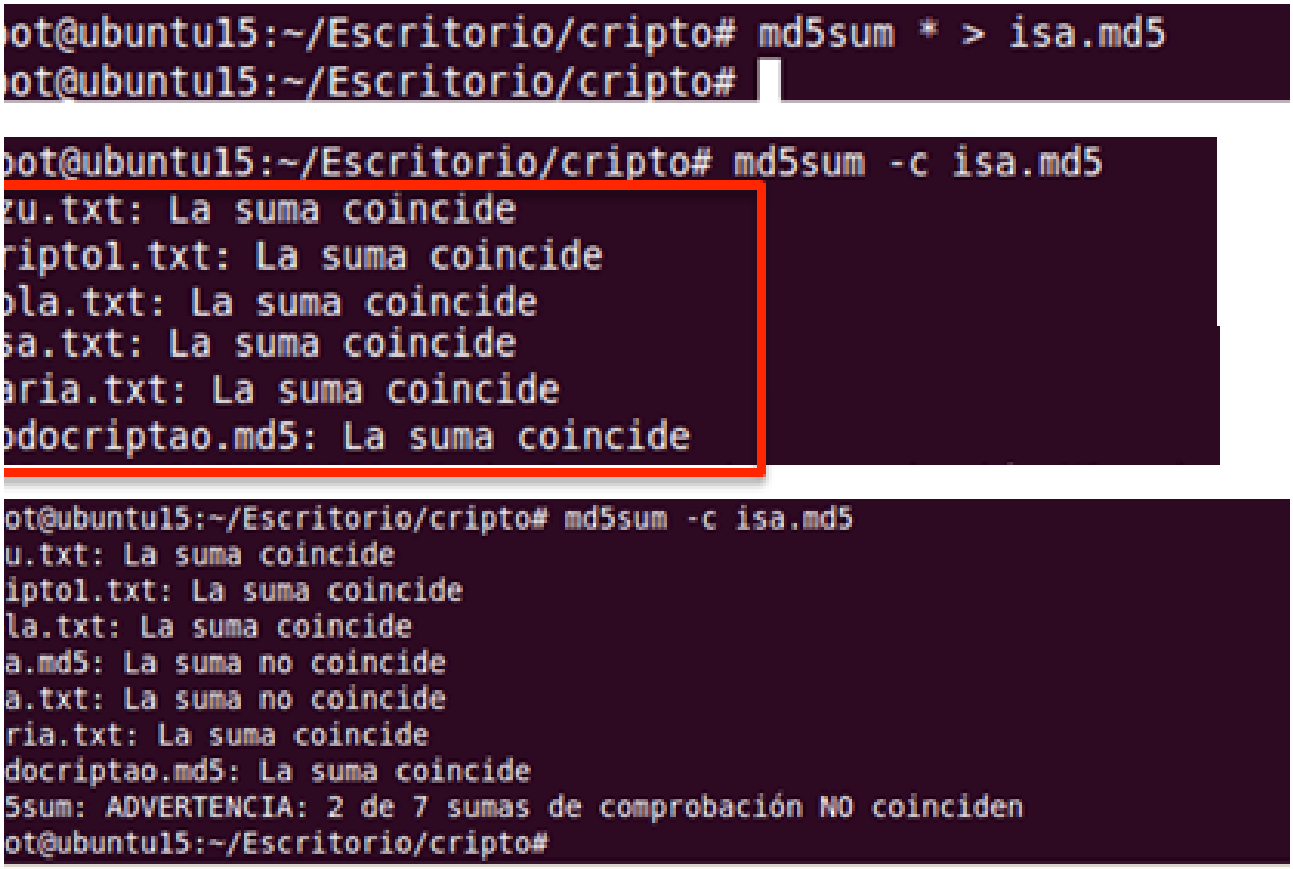


Fig.8. Algoritmo MD5.

9. Listas de control de acceso

Las Listas de Control de Acceso (**ACL**, por sus siglas en inglés) son herramientas utilizadas en seguridad informática para **controlar y gestionar el acceso a recursos o sistemas**. Las ACL se basan en reglas que establecen qué tipo de acceso está permitido o denegado para cada recurso. Estas reglas pueden incluir permisos de lectura, escritura, ejecución o denegación de acceso. Cuando un usuario o dispositivo intenta acceder a un recurso, el sistema consultará la ACL correspondiente y tomará decisiones basadas en las reglas establecidas.

Las ACL permiten un **control de acceso granular**, lo que significa que se pueden establecer permisos específicos para usuarios individuales, grupos de usuarios o categorías de usuarios. Esto facilita una gestión más eficiente y flexible de los recursos y permite adaptarse a diferentes escenarios de seguridad.

Se deben mantener y revisar regularmente las ACL para garantizar que sigan siendo relevantes y adecuadas. A medida que cambian las necesidades de seguridad, los usuarios o los recursos, es posible que sea necesario modificar las reglas de las ACL para mantener un nivel óptimo de protección y cumplimiento.

Recuerda que...

Las Listas de Control de Acceso son una herramienta esencial en la seguridad informática, ya que ayudan a garantizar que solo los usuarios autorizados tengan acceso a los recursos adecuados.

Hay diferentes tipos de ACL que se utilizan según el contexto y el sistema operativo. Algunos ejemplos incluyen:

1. **Listas de Control de Acceso de Archivos (FACL)**: Se aplican a archivos y directorios en sistemas de archivos. Permiten definir los permisos de acceso para usuarios y grupos específicos.

2. **Listas de Control de Acceso de Red (RACL)**: Se utilizan en dispositivos de red, como rúteres o firewalls, para controlar el acceso a través de redes. Permiten especificar reglas de filtrado de paquetes basadas en direcciones IP, puertos y otros criterios.



Fig.9. Mensaje de recurso no disponible.

3. **Listas de Control de Acceso a Nivel de Objeto (OACL)**: Se aplican a bases de datos o aplicaciones que tienen su propio modelo de seguridad. Permiten definir permisos a nivel de objeto, como tablas, vistas o procedimientos almacenados.

10. Resumen y resolución del caso práctico de la unidad

En el tema se ha presentado la seguridad lógica como un conjunto de medidas para proteger la información digital, asegurando su integridad, confidencialidad y disponibilidad. Se ha explicado la criptografía como herramienta clave, distinguiendo entre criptografía simétrica (misma clave) y asimétrica (clave pública y privada). También se han visto sus principales algoritmos y usos.

Se han abordado las funciones resumen o funciones hash, que permiten verificar si un archivo o mensaje ha sido modificado.

Además, se han tratado distintos métodos de autenticación, como contraseñas robustas, biometría o tarjetas inteligentes, así como buenas prácticas para la gestión segura de contraseñas y el acceso a sistemas.

Finalmente, se han explicado sistemas de identificación, como la firma electrónica, los certificados digitales y el uso del DNI electrónico. También se ha presentado la infraestructura de clave pública (PKI) y las listas de control de acceso, que permiten definir los permisos de los usuarios y refuerzan la protección de los sistemas informáticos.

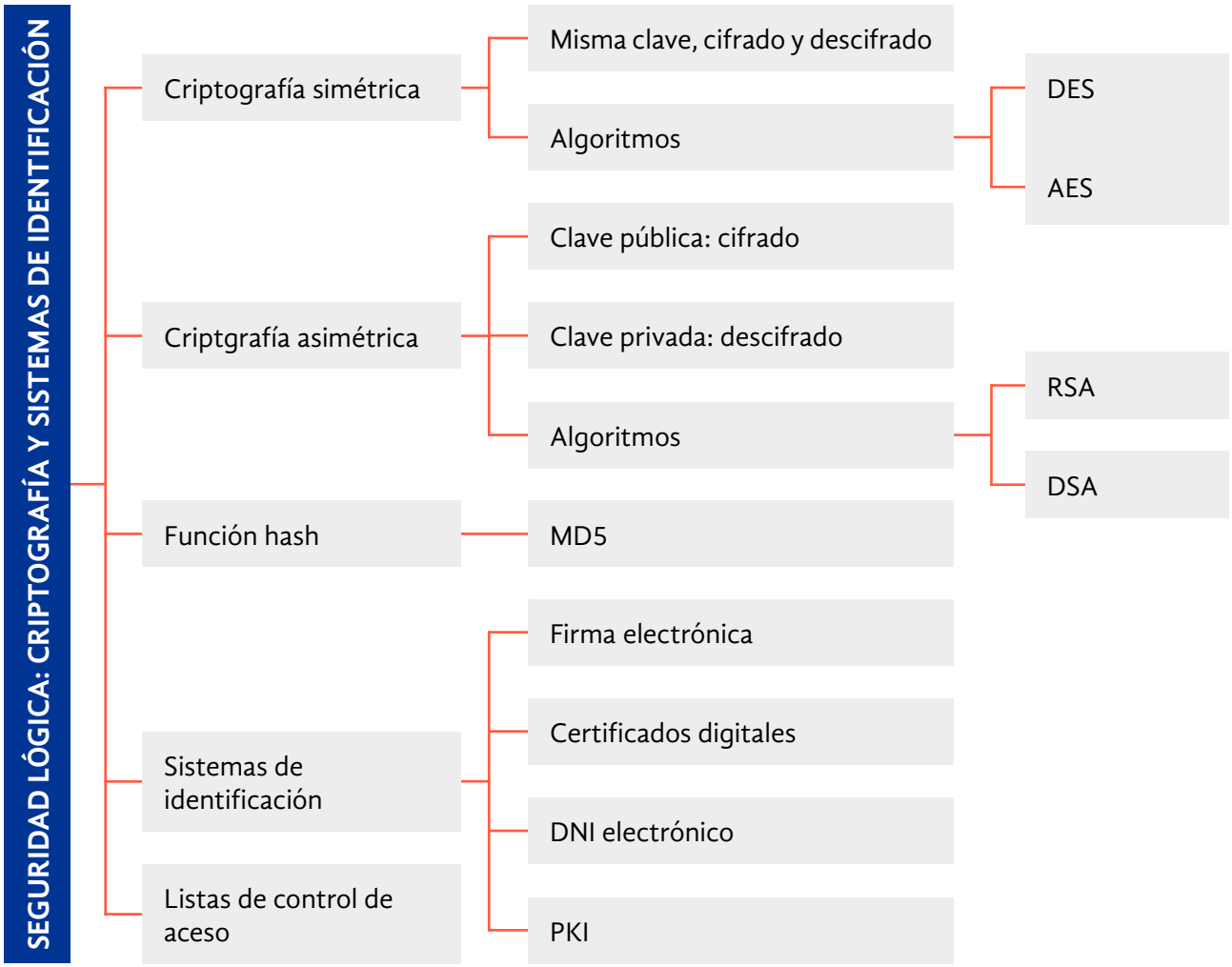


Fig.10. Esquema resumen del tema.

Resolución del caso práctico de la unidad

La empresa debería tomar medidas rápidas y efectivas para mitigar el impacto del incidente.

En primer lugar, se debería revocar el certificado digital robado y generar uno nuevo, lo que impediría al atacante seguir utilizando la clave privada para descifrar y modificar las comunicaciones.

En segundo lugar, se deberían implementar controles adicionales de seguridad, como la autenticación de dos factores, para reforzar la protección de los sistemas y evitar futuros ataques similares.

Por último, la empresa también podría realizar una investigación exhaustiva para identificar al responsable y tomar acciones legales en su contra. A través de su respuesta diligente y mejora de las medidas de seguridad, la empresa lograría recuperar la confianza de sus clientes y restablecer su reputación en el mercado.

11. Bibliografía

Santos, J. C. (2011). *Seguridad y Alta Disponibilidad (GRADO SUPERIOR)*. Ra-Ma Editorial.

Postigo Palacios, A. (2020). *Seguridad informática (Edición 2020)*. Ediciones Paraninfo, SA.

Alegre Ramos, M. D. P., & García-Cervigón Hurtado, A. (2011). *Seguridad informática*. Ediciones Paraninfo, S. A.

Vieites, Á. G. (2011). *Enciclopedia de la seguridad informática (Vol. 6)*. Grupo Editorial RA-MA.

Blancas Martínez, J. D. J., & Franco Ayala, A. (2010). *Estrategias de seguridad lógica*.